

INTERNSHIP ASSIGNMENT SUBMISSION

Independent Policy Developer & Governance Consultant

HEALTHBRIDGE MEDICAL
SYSTEMS

Comprehensive Information Security
Policy

Enterprise Governance, Risk Management & Compliance Framework

Policy Reference: HBM-ISP-2025-001 | Version 1.0

Document Details	
Prepared By	Shubham Nirmal
Intern ID	2160
Organization	RedKross Intelligence
Hypothetical Entity	HealthBridge Medical Systems (HMS)
Policy Type	Information Security Policy (ISP)
Version	1.0 – Draft for Evaluation
Date	June 2025
Classification	ACADEMIC SUBMISSION – CONFIDENTIAL

Assignment Context

This policy document is an academic submission prepared by Shubham Nirmal (Intern ID: 2160) as part of an internship programme at RedKross Intelligence. HealthBridge Medical Systems is a fictional organization created solely for this assignment. All persons, systems, incidents, and regulatory references are illustrative and educational in nature.

Document Control

Policy Title

Comprehensive Information Security Policy

Policy Reference

HBM-ISP-2025-001

Version

1.0 (Draft)

Prepared By

Shubham Nirmal – Intern, RedKross Intelligence (ID: 2160)

Submission Context

Internship Assignment – Independent Policy Developer & Governance Consultant Role

Hypothetical Entity

HealthBridge Medical Systems (HMS)

Industry Sector

Healthcare – Electronic Medical Records & Telehealth Services

Review Cycle

Annual (or triggered by material change)

Next Review Date

June 2026

Standards Alignment

ISO/IEC 27001:2022 | NIST CSF 2.0 | HIPAA | CIS Controls v8 | NIST SP 800-53

Version	Date	Author	Change Description
0.1	April 2025	Shubham Nirmal (Intern)	Initial draft – scenario and structure
0.2	May 2025	Shubham Nirmal (Intern)	Core sections populated through Section 10
1.0	June 2025	Shubham Nirmal (Intern)	Complete policy – submitted for evaluation

Table of Contents

Section 1: Executive Summary

1.1 Organization Overview

HealthBridge Medical Systems (HMS) is a hypothetical mid-sized healthcare technology organization headquartered in Chicago, Illinois. With approximately 1,800 employees across four regional offices, HMS delivers Electronic Medical Record (EMR) software, telehealth platforms, and medical billing services to over 340 hospital networks and 2,100 independent clinics across the United States. The organization processes in excess of 4.2 million patient records annually and handles sensitive financial transactions totalling USD 380 million in medical billing operations each year.

1.2 Business Environment

HMS operates at the intersection of healthcare delivery, financial services, and information technology. This convergence creates an exceptionally complex risk environment: the organization is simultaneously a custodian of Protected Health Information (PHI) regulated under HIPAA, a processor of payment card data subject to PCI DSS, and a critical supplier to healthcare entities whose operational continuity directly affects patient safety. The COVID-19 pandemic accelerated HMS's expansion into telehealth services, rapidly increasing the attack surface through remote access infrastructure, third-party API integrations, and cloud-hosted patient data repositories.

1.3 Purpose of the Policy

This Comprehensive Information Security Policy (CISP) establishes the governance framework, security controls, risk management methodology, and compliance obligations necessary to protect HMS's information assets, fulfil regulatory requirements, and sustain the trust of patients, clinical partners, and regulators. The policy applies to all HMS information systems, personnel, and third-party service providers and is formally aligned with ISO/IEC 27001:2022, the NIST Cybersecurity Framework 2.0, HIPAA Security Rule requirements, and CIS Controls v8.

Policy Mandate

Executive leadership of HealthBridge Medical Systems has mandated that information security be treated as a strategic business function and a patient safety imperative. Full compliance with this policy is non-negotiable for all personnel, systems, and vendors within scope.

Section 2: Hypothetical Scenario

2.1 Company Profile

Parameter	Details
Company Name	HealthBridge Medical Systems (HMS) – Fictional Entity
Founded	2011 (hypothetical)
Headquarters	Chicago, Illinois, USA
Employee Count	~1,800 full-time; ~240 contractors and consultants
Annual Revenue	USD 420 million (hypothetical)
Clients	340 hospital networks; 2,100 independent clinics; 18 health insurance payers
Data Under Management	4.2M+ active patient records; 890,000 telehealth sessions annually
Cloud Footprint	AWS (primary); Azure (DR and telehealth); on-premises data centres x 2
Regulatory Regime	HIPAA/HITECH; PCI DSS; SOC 2 Type II; Illinois Personal Information Protection Act
Certifications Held	ISO 27001:2022 (target); SOC 2 Type II (current)

2.2 Business Operations

- EMR Platform (HealthBridge Core):**
 - Cloud-hosted EMR serving 340 hospital networks. Contains full patient demographic, clinical history, diagnostic, and prescription data. API integrations with 140+ third-party clinical applications.
- Telehealth Services (HealthBridge Connect):**
 - Real-time video consultation platform integrated with EMR. 890,000 sessions annually. Patient access via web and mobile applications. Clinician access via dedicated desktop client.
- Medical Billing Platform (HealthBridge Pay):**
 - Claims processing, payment reconciliation, and patient billing. Processes payment card transactions and interfaces with insurance payer networks. PCI DSS scope applies to this platform.
- Clinical Analytics (HealthBridge Insights):**
 - De-identified population health analytics and reporting. Supplied to hospital network administrators and public health authorities.

2.3 Key Assets and Stakeholders

Asset Category	Examples	Value / Sensitivity
Patient PHI	Medical records, diagnoses, prescriptions, demographics	Critical – Regulatory / Patient Safety
Clinical IP	Proprietary EMR algorithms, telehealth platform code	High – Competitive / Commercial
Financial Data	Payment card data, claims data, payer contracts	High – Regulatory (PCI DSS, HIPAA)
Infrastructure	AWS/Azure environments, on-prem data	High – Operational Continuity

	centres, endpoints	
Third-Party APIs	EHR integrations, pharmacy networks, lab interfaces	Medium-High – Supply Chain Risk
Employee HR Data	Personnel files, credentials, payroll data	Medium – Privacy / Compliance
Audit & Log Data	SIEM logs, access records, compliance evidence	High – Regulatory / Forensic

2.4 Risk Landscape Overview

HMS's risk landscape is shaped by four converging forces: the high commercial value of healthcare data on dark-web markets (medical records fetching up to USD 250 each per security researchers); the mandatory regulatory obligations under HIPAA with potential fines reaching USD 1.9 million per violation category per year; the operational interdependence of HMS systems with clinical care delivery; and the rapidly evolving threat actor ecosystem targeting healthcare organisations with ransomware, business email compromise, and supply chain attacks.

Section 3: Policy Scope

3.1 Departments Covered

- Information Technology Department (all sub-teams including infrastructure, application development, cloud operations, and security)
- Clinical Operations (all staff interacting with EMR or telehealth platforms)
- Medical Billing and Revenue Cycle Management
- Human Resources (employee data management and onboarding/offboarding)
- Finance and Accounting (financial systems and payment processing)
- Legal and Compliance
- Executive Leadership and Board-level governance functions
- Customer Success and Client-Facing Operations

3.2 Users Covered

- All full-time and part-time HMS employees regardless of role or seniority
- Contracted staff, consultants, temporary workers, and interns with access to HMS systems
- Third-party service providers, vendors, and partners with access to HMS information assets or systems
- Board members and executive leadership with access to sensitive organizational data

3.3 Systems Covered

- All HMS-owned or HMS-operated information systems including servers, workstations, laptops, mobile devices, and networking equipment
- Cloud environments hosted on AWS, Azure, or any other cloud service provider used by HMS
- All applications developed or procured by HMS, including EMR, telehealth, billing, and analytics platforms
- Network infrastructure including firewalls, VPNs, switches, wireless access points, and remote access gateways
- Physical data centres and server rooms operated by or on behalf of HMS
- Any system that stores, processes, or transmits PHI, payment card data, or other regulated information

3.4 Exclusions and Limitations

Scope Exclusion Note

The following are explicitly excluded from this policy scope: (1) Personal devices not enrolled in the HMS Mobile Device Management (MDM) programme; (2) Systems operated solely by client organizations that do not process HMS data; (3) Third-party SaaS platforms where HMS has no administrative control, provided a Business Associate Agreement (BAA) and TPSP risk assessment are in place. All exclusions must be formally documented and approved by the CISO.

Section 4: Policy Statement

4.1 High-Level Policy Declaration

HealthBridge Medical Systems is committed to protecting the confidentiality, integrity, and availability of all information assets entrusted to the organization by patients, clinical partners, employees, and regulators. Information security is not a technical function alone but a fundamental governance obligation, a patient safety imperative, and a competitive differentiator. HMS shall implement, operate, and continuously improve an Information Security Management System (ISMS) aligned with ISO/IEC 27001:2022 to systematically manage information risk in proportion to its likelihood and business impact.

4.2 Organizational Commitment

- HMS shall allocate adequate financial, human, and technological resources to maintain a robust information security programme proportionate to the sensitivity of the data managed and the evolving threat landscape.
- Executive leadership shall champion a security-aware culture in which every employee understands their responsibility for protecting patient data and organizational assets.
- HMS shall comply with all applicable laws, regulations, and contractual obligations governing the security and privacy of health information, payment data, and personal data.
- Security incidents shall be managed transparently and in compliance with mandatory breach notification requirements under HIPAA/HITECH.

4.3 Security and Compliance Expectations

All personnel with access to HMS information systems are individually responsible for complying with this policy and the supporting standards, procedures, and guidelines published under its authority. Non-compliance shall be treated as a disciplinary matter and, where criminal conduct is suspected, referred to law enforcement. Third-party service providers must demonstrate equivalent security standards as a condition of engagement and must maintain compliance throughout the contractual relationship.

Section 5: Policy Objectives

This policy is designed to achieve the following measurable security objectives, each tracked through defined Key Performance Indicators (KPIs) reviewed quarterly by the CISO and annually by the Board:

Objective	Description	KPI / Success Metric	Target
O-1: Risk Reduction	Systematically identify and treat information risks to an acceptable level	% of High/Critical risks treated within SLA	>= 95% within 30 days
O-2: Asset Protection	Ensure all PHI and regulated data is protected from unauthorised access, disclosure, or corruption	Zero confirmed unencrypted PHI exposures	0 incidents annually
O-3: Regulatory Compliance	Maintain continuous compliance with HIPAA, PCI DSS, SOC 2, and ISO 27001	Annual audit findings – critical/high	0 critical; <= 3 high
O-4: Business Continuity	Ensure critical clinical systems recover within defined RTO/RPO targets following any disruption	RTO for HealthBridge Core	<= 4 hours
O-5: Incident Management	Detect, contain, and resolve security incidents within defined timelines	Mean Time to Contain (MTTC) – P1 incidents	<= 2 hours
O-6: Awareness & Training	Ensure all personnel are trained in security responsibilities relevant to their role	Annual security training completion rate	>= 98%
O-7: Vendor Risk	Maintain assessed, contractually secured TPSP relationships	% of critical vendors with current BAA/TPSP assessment	100%
O-8: Vulnerability Mgmt	Identify and remediate vulnerabilities in a risk-proportionate manner	Critical vulnerability mean time to patch	<= 30 days

Section 6: Security Principles

The following principles constitute the philosophical and governance foundation of HMS's information security programme. All security controls, procedures, and governance mechanisms implemented under this policy shall be designed to uphold these principles:

Principle	Definition	HMS Application
Confidentiality	Information is accessible only to authorised individuals, systems, and processes	Role-based access control; encryption of PHI at rest and in transit; MFA for all clinical system access
Integrity	Information is accurate, complete, and protected from unauthorised modification	Digital signing of clinical records; file integrity monitoring; database audit trails; change management controls
Availability	Information systems and data are accessible to authorised users when needed	Redundant infrastructure; 99.9% SLA for HealthBridge Core; defined RTO/RPO; disaster recovery testing
Accountability	All actions on information systems are attributable to a unique, identified individual	Unique user IDs mandatory; shared accounts prohibited; comprehensive audit logging; PAM session recording
Non-Repudiation	Actions performed on information systems cannot be credibly denied by the actor	Digital signatures for critical clinical transactions; tamper-evident audit logs; chain-of-custody documentation
Privacy	Personal data is collected, processed, and retained only as necessary and in accordance with applicable law	Privacy by design in system development; HIPAA Privacy Rule compliance; data minimisation and retention policies
Least Privilege	Access rights are limited to the minimum necessary for legitimate job function	RBAC with quarterly access reviews; JIT privileged access; service account privilege management
Defence in Depth	Multiple overlapping security layers ensure no single control failure leads to catastrophic compromise	Layered controls: perimeter, network, endpoint, application, data, and user layers all independently secured

Section 7: Threat Assessment

7.1 Threat Landscape Summary

Healthcare organizations represent the single most targeted sector for cybercrime by data volume in the United States, accounting for 34% of all reported data breaches in 2023 (HHS, 2023). HMS's specific threat landscape is shaped by its custody of high-value PHI, its role as a critical clinical supplier, and its complex third-party integration ecosystem. The following table identifies the primary threat categories applicable to HMS, categorised by source:

7.2 Threat Matrix

Threat Category	Source	Attack Vector	Likelihood	Impact	Risk Level
Ransomware Attack	External – Cybercriminal	Phishing email; exploit unpatched system	HIGH	CRITICAL	CRITICAL
PHI Data Exfiltration	External – Nation State/Criminal	Supply chain compromise; web app exploit	HIGH	CRITICAL	CRITICAL
Insider Threat – Malicious	Internal – Employee/Contractor	Abuse of legitimate access; privilege escalation	MEDIUM	CRITICAL	HIGH
Business Email Compromise	External – Criminal	Spear-phishing executives; vendor impersonation	HIGH	HIGH	HIGH
Supply Chain Attack	External – Nation State	Compromise of third-party software or API	MEDIUM	CRITICAL	HIGH
Credential Stuffing / Brute Force	External – Automated	Internet-facing telehealth/EMR login portals	HIGH	HIGH	HIGH
Unpatched Vulnerability Exploit	External – Criminal/State	Known CVEs in EMR/web application components	MEDIUM	HIGH	HIGH
Insider Threat – Negligent	Internal – Employee	Misdelivery of PHI; misconfigured cloud storage	HIGH	MEDIUM	MEDIUM
DDoS Against Clinical Systems	External – Criminal/Hacktivist	Botnet-driven volumetric attack on APIs	MEDIUM	HIGH	MEDIUM
Physical Theft / Loss	Internal/External	Theft of unencrypted laptops or portable media	LOW	HIGH	MEDIUM
Advanced Persistent Threat	External – Nation State	Long-dwell lateral movement in EMR environment	LOW	CRITICAL	MEDIUM
Human Error – Configuration	Internal – IT Staff	Misconfigured S3 bucket; open cloud storage	MEDIUM	HIGH	MEDIUM

Likelihood and Impact rated: LOW / MEDIUM / HIGH / CRITICAL. Risk Level = combined qualitative assessment.

7.3 Specific Threat Narratives

7.3.1 People Threats

- Malicious insiders represent the highest-severity insider threat. Clinical staff with legitimate EMR access have the technical ability to bulk-export patient records. Mitigation requires UEBA, access logging, and DLP controls.
- Negligent employees are the most likely cause of PHI exposure events. Misconfigured email CC fields, unencrypted USB drives, and improper disposal of printed records account for the majority of low-severity breach notifications.

7.3.2 Process Threats

- Inadequate change management processes in clinical system deployments create unreviewed configuration changes that introduce vulnerabilities. Formal CAB (Change Advisory Board) processes mitigate this risk.
- Vendor onboarding without security due diligence allows third parties with weak security postures to become supply chain entry points. Formalised TPSP assessment processes are required.

7.3.3 Technology Threats

- Unpatched vulnerabilities in EMR application components and underlying operating systems represent the primary technically-exploitable attack surface. Timely patch management is critical.
- Misconfigured cloud storage (e.g., publicly accessible AWS S3 buckets) has been responsible for the majority of large-scale healthcare data exposures in recent years.

7.3.4 Physical Infrastructure Threats

- Theft of unencrypted mobile devices used by clinicians for telehealth consultations could expose patient PHI if full-disk encryption and remote wipe capabilities are not enforced.
- Physical access to server rooms and networking infrastructure by unauthorised personnel could allow hardware implantation, data extraction, or sabotage.

Section 8: Key Security Controls

8.1 Control Framework Overview

HMS implements a layered security control architecture based on the NIST SP 800-53 control families and CIS Controls v8. Controls are classified as Preventive, Detective, or Corrective and are organised across five protection layers: Perimeter, Network, Endpoint, Application, and Data. The following sections define the mandatory controls within each major domain:

8.2 Access Control and Identity Management

- All HMS information systems SHALL enforce Role-Based Access Control (RBAC). Access roles shall be defined and documented for each system, aligned to job function, and reviewed quarterly by system owners.
- Every user SHALL have a unique, individual user account. Shared or group accounts are strictly prohibited except for specific service accounts managed through the PAM platform.
- Multi-Factor Authentication (MFA) is mandatory for all access to clinical systems, cloud environments, VPN, and any system storing or processing PHI or payment card data. FIDO2/WebAuthn hardware tokens are required for privileged accounts.
- The principle of least privilege SHALL be applied to all access assignments. Excessive permissions identified during quarterly access reviews shall be revoked within 10 business days.
- Privileged accounts (domain administrators, database administrators, cloud super-admins) SHALL be managed through a Privileged Access Management (PAM) platform with session recording, just-in-time access provisioning, and automatic credential rotation.

8.3 Authentication Standards

Access Type	Minimum Authentication Requirement	Preferred Method
Standard user – internal systems	Password + MFA (TOTP minimum)	Password + FIDO2 hardware token
Clinician – EMR and telehealth	Password + MFA (mandatory)	SSO with FIDO2 / smartcard
Remote access (VPN/Remote Desktop)	Password + MFA (mandatory)	Certificate + FIDO2 hardware token
Privileged / administrative access	MFA (phishing-resistant mandatory)	FIDO2 hardware token (AAL3)
Patient portal access (external users)	Password + SMS/email OTP minimum	FIDO2 passkey (promoted)
API service-to-service	Mutual TLS + signed JWT	Certificate-based mTLS
Physical access – data centre	Badge + PIN + biometric	Badge + biometric (fingerprint/iris)

8.4 Data Protection and Encryption

- All PHI at rest in HMS databases, file stores, and cloud storage SHALL be encrypted with AES-256. Disk-level encryption alone is insufficient; field-level database encryption is required for high-sensitivity data elements.

- All PHI in transit SHALL be protected with TLS 1.2 minimum (TLS 1.3 required for new implementations). SSL and TLS versions below 1.2 are explicitly prohibited.
- Payment card data (PAN, track data, CVV) is subject to PCI DSS controls. Full PANs shall not be stored. Tokenisation shall replace PANs in all downstream billing systems.
- Cryptographic key management shall use FIPS 140-2 Level 3 validated HSMs for all keys protecting PHI or payment data. Keys shall be rotated at minimum annually.
- Personal devices used for HMS business must have full-disk encryption enforced through the MDM platform. Remote wipe capability must be active for all enrolled devices.

8.5 Backup and Recovery

- All clinical data shall be backed up daily with a backup retention period of 90 days online and 7 years in cold storage (meeting HIPAA medical record retention requirements).
- Backups shall be encrypted with separate keys from production systems. Backup integrity shall be verified through automated restoration tests monthly.
- Recovery Time Objective (RTO) for HealthBridge Core EMR: 4 hours. Recovery Point Objective (RPO): 1 hour.
- Full disaster recovery testing shall be conducted at minimum semi-annually. Test results shall be documented and reviewed by the CISO.

8.6 Logging, Monitoring and SIEM

- All systems within scope SHALL generate audit logs meeting the requirements of HIPAA § 164.312(b) and NIST SP 800-92. Logs shall include: user identity; event type; date/time; source/destination; success/failure.
- A Security Information and Event Management (SIEM) platform shall aggregate, normalise, and correlate logs from all in-scope systems in real-time. Automated alerting rules shall cover all priority threat scenarios.
- Log retention shall meet HIPAA's 6-year retention requirement. Logs shall be stored in tamper-evident, write-once or WORM storage with integrity verification.
- A dedicated Security Operations Center (SOC) function shall provide 24/7/365 monitoring of SIEM alerts and shall escalate confirmed incidents per the Incident Response procedure.

8.7 Vulnerability Management

- Internal vulnerability scans of all in-scope systems shall be conducted at minimum monthly. External scans shall be conducted quarterly by a qualified external party.
- Critical vulnerabilities (CVSS ≥ 9.0) shall be remediated within 30 days. High vulnerabilities (CVSS 7.0–8.9) within 60 days. Exceptions require CISO approval and documented compensating controls.
- All web applications processing PHI or payment data shall undergo OWASP Top 10 penetration testing at minimum annually and following material application changes.

8.8 Incident Response

- HMS shall maintain a documented Incident Response Plan (IRP) covering preparation, detection, containment, eradication, recovery, and post-incident review phases.
- HIPAA breach notification obligations shall be integrated into the IRP. Individuals whose PHI has been breached shall be notified within 60 days of discovery. HHS shall be notified annually (or within 60 days for breaches affecting ≥ 500 individuals).
- The IRP shall be tested at minimum annually through tabletop exercises. Full incident simulation exercises shall be conducted bi-annually.

Section 9: Governance Framework

9.1 Information Security Governance Structure

HMS adopts a three-tier governance structure for information security: strategic governance at Board and executive level, tactical governance through the Information Security Steering Committee (ISSC), and operational governance through the CISO and security team. This structure ensures that security decisions are made at the appropriate level with adequate authority, expertise, and accountability.

Governance Tier	Body / Role	Responsibilities	Meeting Frequency
Strategic	Board of Directors – Audit & Risk Committee	Approve information security strategy; review risk appetite; receive annual CISO briefing; approve policy framework	Annually (security agenda); Quarterly (risk updates)
Strategic	Chief Executive Officer	Champion security culture; ensure adequate resource allocation; receive executive security briefings	As required / quarterly
Tactical	Information Security Steering Committee (ISSC)	Review security programme; approve major changes; review quarterly KPIs; oversee policy updates	Quarterly
Tactical	Chief Information Security Officer (CISO)	Policy ownership; risk management; programme leadership; regulatory liaison; incident escalation	Daily operations; monthly executive reporting
Operational	IT Security Team	Technical control implementation; SIEM monitoring; vulnerability management; incident response	Daily
Operational	Data Protection Officer (DPO)	HIPAA Privacy Rule compliance; BAA management; breach notification coordination	As required; monthly reporting
Operational	Compliance Manager	Policy adherence monitoring; audit coordination; regulatory submission management	Weekly

9.2 Decision-Making Authority Matrix

Decision Type	Decision Authority	Consultation Required
New information security policy adoption	CISO + ISSC approval	Legal, IT, DPO, impacted business units
Risk acceptance above risk appetite threshold	CEO approval required	CISO, Legal, ISSC
Major security architecture change	CISO approval	IT Architecture, affected system owners
Security incident escalation to P1	CISO notification (immediate)	CEO, Legal (if PHI breach suspected)

HIPAA breach notification determination	DPO + Legal + CISO	CEO informed; external counsel engaged
Third-party vendor security exception	CISO approval	Compliance, Legal, procurement
Security budget allocation	CFO + CEO approval	CISO input; Board ratification for major items

9.3 Policy Review and Escalation Process

This policy shall be reviewed annually by the CISO and Compliance Manager. Reviews shall assess: changes to the regulatory landscape; new or evolved threats; lessons learned from security incidents; changes to HMS's business operations or technology environment; and recommendations from external auditors or penetration testers. Material policy updates shall be reviewed by the ISSC and approved by the CISO before re-issuance. Emergency updates required by regulatory changes or significant incidents may be issued by the CISO with ISSC ratification at the next scheduled meeting.

Section 10: Monitoring and Enforcement

10.1 Compliance Monitoring Programme

HMS shall maintain a continuous compliance monitoring programme to verify that security controls defined in this policy are operational, effective, and consistently applied. The compliance monitoring programme comprises automated technical controls, periodic internal audits, and annual third-party assessments.

Monitoring Activity	Method	Frequency	Responsible Owner	Reporting Destination
Vulnerability scanning – internal	Automated scanning tool	Monthly	IT Security	CISO dashboard; monthly report
Vulnerability scanning – external	Approved external scanning vendor	Quarterly	IT Security / Vendor	Compliance Manager; CISO
SIEM alert review	SOC analyst review of SIEM	Daily	SOC	Weekly SOC metrics report to CISO
Access control / RBAC review	Manual review with IAM exports	Quarterly	IT Security + HR	CISO; ISSC quarterly report
Privileged access review	PAM platform audit reports	Quarterly	IT Security	CISO; Compliance Manager
Patch compliance check	Vulnerability management platform	Monthly	IT Security	CISO; monthly compliance report
Security awareness training tracking	LMS completion reports	Monthly	HR + Compliance	CISO; ISSC quarterly report
Third-party compliance review (TPSP)	TPSP questionnaires; AOCs; BAA review	Annually + at onboarding	Compliance	DPO; CISO
Penetration testing	Qualified pen tester	Annually	CISO	ISSC; Board Audit Committee
Internal policy compliance audit	Internal audit function	Annually	Compliance Manager	CISO; ISSC; Board
External ISO 27001 / SOC 2 audit	Accredited external auditor / CPA	Annually	CISO + Compliance	Board Audit Committee; clients

10.2 Violation Handling and Corrective Action

Violation Severity	Examples	Immediate Action	Consequence Range
Low	Missed training deadline; minor policy deviation; late patch	Notification to manager; mandatory remediation	Written warning; mandatory retraining
Medium	Credential sharing; unauthorised software; undocumented access	Account suspension pending review; manager notification	Formal disciplinary warning; access restriction
High	Deliberate bypass of security controls; unauthorised PHI access	Immediate account suspension; CISO notification	Disciplinary action up to termination; legal review

Critical	Deliberate PHI exfiltration; sabotage; fraud using HMS systems	Immediate suspension; incident response activation	Immediate termination; law enforcement referral; civil/criminal liability
----------	--	--	---

Section 11: Compliance Requirements

11.1 Regulatory and Standards Alignment

HealthBridge Medical Systems operates under a multi-framework compliance obligation. The following table maps the key regulatory and standards requirements applicable to HMS against the relevant policy sections and implementing controls. This mapping serves as the basis for HMS's unified compliance programme, enabling shared evidence collection and minimising duplication of compliance effort.

Standard / Regulation	Applicability to HMS	Key Requirements	Relevant Policy Section(s)
HIPAA Security Rule (45 CFR §164)	PRIMARY – mandatory	PHI safeguards; access controls; audit logs; encryption; breach notification; risk analysis	Sections 5, 7, 8, 9, 10, 12
HIPAA Privacy Rule	PRIMARY – mandatory	Minimum necessary standard; patient rights; BAA requirements; uses and disclosures	Sections 3, 4, 9, 13
HITECH Act	PRIMARY – mandatory	Enhanced breach notification; business associate liability; increased civil/criminal penalties	Sections 10, 13
PCI DSS v4.0	APPLICABLE – HealthBridge Pay platform	CDE security; encryption; MFA; vulnerability management; logging; network segmentation	Sections 8, 9, 10, 12
ISO/IEC 27001:2022	TARGET CERTIFICATION	ISMS governance; risk assessment; Annex A controls; continual improvement	Sections 5, 6, 9, 12, 15
NIST CSF 2.0	VOLUNTARY FRAMEWORK	Govern; Identify; Protect; Detect; Respond; Recover functions	Sections 7, 8, 9, 10, 12
NIST SP 800-53 Rev. 5	REFERENCE FRAMEWORK	Security and privacy control families (AC, AU, CM, CP, IA, IR, SI, SC, etc.)	Section 8 (all controls)
CIS Controls v8	IMPLEMENTATION GUIDE	18 control families from asset inventory to penetration testing	Sections 8, 10
Illinois PIPA	STATE LAW – mandatory	Data breach notification to Illinois residents; reasonable security measures	Sections 10, 13
SOC 2 Type II	CURRENT CERTIFICATION	Trust Services Criteria: Security, Availability, Confidentiality, Privacy, Processing Integrity	Sections 6, 8, 9, 10

11.2 Assumptions Underpinning Compliance Framework

Policy Assumptions

The following assumptions were made in developing this policy: (1) HMS is a HIPAA Covered Entity (CE) directly subject to HIPAA Security and Privacy Rules; (2) All third-party vendors with PHI access have executed Business Associate Agreements (BAAs); (3) HMS's PCI DSS compliance scope is limited to the HealthBridge Pay billing platform; (4) The

organisation has achieved or is actively pursuing ISO 27001:2022 certification; (5) Budget and staffing are assumed sufficient to implement all required controls, subject to resource prioritisation through the risk management framework; (6) Local Illinois law requirements supplement but do not replace federal HIPAA obligations.

Section 12: Risk Management Framework

12.1 Risk Management Methodology

HMS adopts a risk management methodology aligned with ISO 31000:2018 and ISO/IEC 27005:2022, adapted to the healthcare sector's specific risk profile. The risk management lifecycle is embedded into business operations through annual risk assessments, continuous monitoring, and event-triggered reviews. Risk appetite is defined by the Board and operationalised through risk treatment thresholds maintained by the CISO.

12.2 Risk Scoring Matrix

Impact \ Likelihood	1 - Rare	2 - Unlikely	3 - Possible	4 - Likely	5 - Almost Certain
5 - Catastrophic	5	10	15	20	25
4 - Major	4	8	12	16	20
3 - Moderate	3	6	9	12	15
2 - Minor	2	4	6	8	10
1 - Negligible	1	2	3	4	5

Risk Score = Likelihood x Impact. 1-5: LOW (green) | 6-12: MEDIUM (amber) | 13-19: HIGH (orange) | 20-25: CRITICAL (red).

12.3 Risk Treatment Options

Treatment Option	Description	When Applicable	HMS Example
Mitigate (Reduce)	Implement controls to reduce likelihood or impact to acceptable level	Primary treatment for HIGH and CRITICAL risks	Deploy MFA to reduce credential theft risk
Transfer	Shift financial consequence through insurance or contractual arrangements	Residual risk following mitigation; financial risks	Cyber liability insurance covering breach costs
Avoid	Discontinue the activity giving rise to the risk	When risk exceeds acceptable threshold and mitigation is not cost-effective	Discontinue use of unencryptable legacy device
Accept	Formally acknowledge and accept residual risk within risk appetite	LOW and some MEDIUM risks where treatment cost exceeds benefit	Accept residual risk of email phishing after controls

12.4 Risk Review Cycle

- Full organisational risk assessment: Annually, led by CISO, reviewed by ISSC and Board.

- System-specific risk assessments: Annually or prior to major system changes, led by system owners with CISO oversight.
- Event-triggered reviews: Following any confirmed security incident, material threat intelligence change, significant regulatory change, or major technology deployment.
- Risk register: Maintained continuously by the CISO and reviewed quarterly by the ISSC.

Section 13: RACI Matrix

13.1 Responsibility Assignment Matrix

The following RACI matrix defines responsibility for key information security activities across HMS stakeholders. R = Responsible; A = Accountable; C = Consulted; I = Informed.

Security Activity	Board / CEO	CISO	IT Security	DPO / Legal	HR	Dept Managers	TPSP
Information Security Strategy & Policy Approval	A	R	C	C	I	I	I
Risk Assessment & Risk Register Management	I	A	R	C	I	C	C
Security Awareness Training Design	I	A	R	C	C	I	I
Security Awareness Training Completion	I	A	C	I	R	R	R
Identity & Access Management	I	A	R	I	C	C	I
Privileged Access Management	I	A	R	I	I	I	I
Vulnerability Management	I	A	R	I	I	I	C
Patch Management	I	A	R	I	I	C	C
Encryption & Key Management	I	A	R	C	I	I	C
SIEM Monitoring & Alert Response	I	A	R	I	I	I	I
Incident Response Activation & Management	I	A/R	R	C	C	C	C
HIPAA Breach Notification	I	C	C	A/R	C	I	C
Third-Party Risk Assessment (TPSP)	I	A	C	R	I	C	R
Physical Access Controls	I	A	C	I	C	R	I
Business Continuity & DR Testing	I	A	R	I	I	C	C
Compliance Audit Coordination	I	A	C	R	C	C	C
Board Security Reporting	A	R	C	C	I	I	I
Security Budget Planning	A	R	C	I	I	I	I

RACI Key: R = Responsible (does the work) | A = Accountable (ultimately answerable) | C = Consulted (provides input) | I = Informed (kept updated)

Section 14: Implementation Roadmap

14.1 Phase-Wise Implementation Plan

HMS's security programme implementation is structured across five phases over an 18-month horizon. The phased approach prioritises the highest-risk controls first, aligns with resource availability, and enables measurable progress tracking against defined milestones.

Phase	Timeframe	Focus Areas	Key Milestones	Success Metrics
Phase 1: Foundation	Months 1–3	Policy approval; asset inventory; HIPAA risk analysis; MFA rollout to all clinical staff; privileged access management deployment	Policy approved; PAM live; MFA at 100% for CDE users	Policy signed off; PAM coverage >= 95%; MFA deployment >= 100% clinical
Phase 2: Core Controls	Months 4–6	SIEM deployment; vulnerability management programme launch; encryption audit and remediation; backup and DR testing	SIEM live with 100% log source coverage; first vulnerability scan cycle complete	SIEM coverage 100%; Critical vulns remediated within SLA >= 90%
Phase 3: Advanced Controls	Months 7–10	UEBA deployment; EDR on all endpoints; WAF hardening; third-party risk programme formalisation; annual pen test	EDR deployed to 100% endpoints; TPSP assessments for all Tier 1 vendors complete	EDR coverage 100%; TPSP programme 100% for critical vendors
Phase 4: Governance Maturity	Months 11–14	ISO 27001 gap assessment; ISSC cadence established; KPI dashboard live; security awareness training 100% completion	ISO 27001 gap report issued; ISSC meeting cadence active; 98% training completion	ISO 27001 readiness >= 80%; training completion >= 98%
Phase 5: Certification & Continuous Improvement	Months 15–18	ISO 27001 certification audit; SOC 2 Type II re-certification; ISSC reviews all KPIs; lessons learned integrated	ISO 27001 Stage 2 audit complete; SOC 2 re-certified	ISO 27001 certified; 0 critical audit findings

14.2 Resource Requirements

Resource Category	Description	Estimated Requirement
Personnel	CISO (if not existing); 2x Security Analysts; 1x Compliance Manager; 1x DPO	5 FTEs estimated (some via reallocation)
Technology – SIEM	Enterprise SIEM platform (e.g., Splunk, Microsoft Sentinel, IBM QRadar)	USD 150,000–280,000 annually (license + infrastructure)
Technology – PAM	Privileged Access Management platform (e.g., CyberArk, BeyondTrust)	USD 80,000–150,000 annually
Technology – EDR	Endpoint Detection & Response (e.g., CrowdStrike Falcon, Microsoft Defender)	USD 60,000–120,000 annually (1,800 endpoints)
Technology – HSM	Hardware Security Module for PHI key management (e.g., Thales Luna)	USD 40,000–90,000 (capital + maintenance)
Pen Testing	Annual external penetration test and web application	USD 30,000–80,000 annually

	assessment	
Audit / Certification	ISO 27001 Stage 1 + Stage 2 audit; SOC 2 Type II audit	USD 50,000–100,000 for initial cycle
Training Platform	Security awareness training platform (e.g., KnowBe4, Proofpoint)	USD 15,000–30,000 annually
Cyber Insurance	Cyber liability insurance covering breach response, notification, and business interruption	USD 80,000–200,000 annually (premium)

Section 15: Review and Maintenance

15.1 Review Frequency

- Annual review: This policy shall be formally reviewed by the CISO and Compliance Manager every 12 months. The review shall assess policy completeness, currency against the regulatory landscape, and continued alignment with the threat environment.
- ISSC ratification: All material policy updates following annual review shall be presented to the Information Security Steering Committee for ratification before re-issuance.
- Board notification: The Board's Audit and Risk Committee shall be notified of all approved policy updates at their next scheduled meeting.

15.2 Policy Update Triggers

In addition to the scheduled annual review, this policy shall be reviewed and updated upon the occurrence of any of the following trigger events:

- A confirmed security incident resulting in PHI exposure or payment data compromise
- A material change to applicable laws or regulations (e.g., HIPAA rule revision, state law change)
- Significant changes to HMS's technology environment, including major new system deployments or cloud migrations
- Recommendations from external auditors, penetration testers, or regulatory inspectors that require policy amendment
- A published change to a referenced standard (ISO 27001, NIST CSF, CIS Controls, PCI DSS) that affects policy requirements
- A significant change to the organisational structure or business operations that affects policy scope

15.3 Change Management Process

Step	Activity	Owner	Timeframe
1	Trigger identified and documented in the policy change log	CISO / Compliance Manager	Immediately upon trigger
2	Impact assessment: What sections are affected? What controls need updating?	CISO	Within 5 business days
3	Draft update prepared and circulated for comment to affected stakeholders	Compliance Manager	Within 15 business days
4	Legal and DPO review (where regulatory change is involved)	Legal / DPO	Within 10 business days of draft
5	CISO approval of final updated text	CISO	Within 5 business days of review completion
6	ISSC ratification (for material changes) or CISO authorisation (for minor updates)	ISSC / CISO	At next scheduled meeting or within 10 days
7	Updated policy published to policy repository; version control updated	Compliance Manager	Within 2 business days of approval

8	All in-scope personnel notified; training updated if required	HR + Compliance	Within 10 business days of publication
---	---	-----------------	--

Section 16: Control Selection Justification

16.1 Rationale for Framework and Control Choices

This section fulfils the assignment requirement to justify the selection of specific controls, standards, and governance measures. Each choice is grounded in the specific risk profile of HealthBridge Medical Systems and in recognised industry evidence:

Control / Standard	Justification for Selection
HIPAA Security Rule alignment	Mandatory federal obligation as a healthcare Covered Entity. Non-compliance exposes HMS to OCR enforcement with penalties up to USD 1.9M per violation category. Every security control defined in this policy is designed to satisfy at least one HIPAA Security Rule requirement.
ISO/IEC 27001:2022 as ISMS framework	ISO 27001 provides the governance architecture (ISMS) that contains and organises all other controls. Hospital network clients increasingly require ISO 27001 certification as a supplier qualification criterion. The standard's risk-based approach is compatible with HIPAA's own risk analysis requirement.
NIST CSF 2.0 as reference model	NIST CSF is the most widely adopted cybersecurity framework in the US healthcare sector (HHS recommends it for HIPAA risk management). The six-function structure (Govern, Identify, Protect, Detect, Respond, Recover) provides an intuitive operational model for communicating security posture to non-technical executives and Board members.
CIS Controls v8 for implementation	CIS Controls provide specific, prioritised technical controls that translate policy obligations into executable implementation tasks. IG2 (Implementation Group 2) controls are appropriate for HMS's size and risk profile. CIS Controls are mapped to HIPAA, making them an efficient implementation pathway.
MFA for all clinical system access	Credential theft (phishing, credential stuffing) is the #1 vector for healthcare data breaches (Verizon DBIR, 2023). MFA eliminates the value of stolen credentials and directly addresses the most prevalent attack vector. NIST SP 800-63B AAL2 provides the technical standard.
PAM for privileged accounts	Privileged account compromise is the primary technique used in large-scale healthcare ransomware attacks. PAM limits the blast radius of a credential compromise to non-privileged access, preventing ransomware operators from achieving the domain admin access needed for destructive encryption.
SIEM for continuous monitoring	HIPAA § 164.312(b) requires audit controls. NIST CSF Detect function requires continuous monitoring. A SIEM is the operationally effective method of meeting both requirements simultaneously while providing the detection capability needed to meet the 2-hour containment objective for P1 incidents.
AES-256 and TLS 1.3 for encryption	NIST SP 800-131A defines AES-256 and TLS 1.3 as approved algorithms through 2030. These choices ensure regulatory longevity and are universally supported across HMS's technology stack. They satisfy both HIPAA encryption addressable specification requirements and PCI DSS v4.0 mandatory encryption requirements for the billing platform.

Section 17: References and Bibliography

This policy references the following standards, regulations, frameworks, and academic/industry sources:

17.1 Regulatory References

- U.S. Department of Health and Human Services. (1996, as amended 2013). Health Insurance Portability and Accountability Act (HIPAA) – Security Rule (45 CFR Part 164). HHS.
- U.S. Department of Health and Human Services. (2009). Health Information Technology for Economic and Clinical Health (HITECH) Act. HHS.
- Illinois General Assembly. (2005, as amended). Personal Information Protection Act (815 ILCS 530). Illinois.
- PCI Security Standards Council. (2022). Payment Card Industry Data Security Standard (PCI DSS) Version 4.0. PCI SSC.

17.2 Standards and Frameworks

- International Organization for Standardization. (2022). ISO/IEC 27001:2022 – Information Security Management Systems. ISO.
- International Organization for Standardization. (2022). ISO/IEC 27005:2022 – Information Security Risk Management. ISO.
- National Institute of Standards and Technology. (2024). NIST Cybersecurity Framework 2.0. NIST. <https://doi.org/10.6028/NIST.CSWP.29>
- National Institute of Standards and Technology. (2020). NIST SP 800-53 Rev. 5 – Security and Privacy Controls for Information Systems and Organizations. NIST.
- National Institute of Standards and Technology. (2017). NIST SP 800-63B – Digital Identity Guidelines: Authentication and Lifecycle Management. NIST.
- National Institute of Standards and Technology. (2012). NIST SP 800-88 Rev. 1 – Guidelines for Media Sanitization. NIST.
- National Institute of Standards and Technology. (2014). NIST SP 800-115 – Technical Guide to Information Security Testing and Assessment. NIST.
- Center for Internet Security. (2021). CIS Controls v8. CIS. <https://www.cisecurity.org/controls>
- OWASP Foundation. (2021). OWASP Top 10 – Web Application Security Risks. <https://owasp.org/Top10>

17.3 Industry and Academic Sources

- Verizon Enterprise Solutions. (2023). 2023 Data Breach Investigations Report (DBIR). Verizon.
- IBM Security & Ponemon Institute. (2023). Cost of a Data Breach Report 2023. IBM Corporation.
- HHS Office for Civil Rights. (2023). HIPAA Breach Report and Enforcement Highlights 2023. HHS.
- Calder, A., & Watkins, S. (2020). IT Governance: An International Guide to Data Security and ISO27001 (7th ed.). Kogan Page.
- Anderson, R., & Moore, T. (2006). The Economics of Information Security. Science, 314(5799), 610–613.
- ISACA. (2022). COBIT 2019 Framework: Introduction and Methodology. ISACA.

Document Sign-Off

This policy document has been prepared as part of an internship assignment at RedKross Intelligence. It demonstrates the application of information security governance, risk management, compliance mapping, and policy development principles to a realistic healthcare sector scenario.

Role	Name	Signature	Date
Policy Author (Intern)	Shubham Nirmal	[Signed]	June 2025
Evaluating Supervisor	[Supervisor Name]	[Pending]	
Assignment Reviewer	[Reviewer Name]	[Pending]	

Prepared By: Shubham Nirmal (Intern ID: 2160) | RedKross Intelligence | June 2025
HealthBridge Medical Systems is a fictional organization created solely for this academic assignment.